

Implementation of SAGA

A Security Architecture for Governing AI Agentic Systems

Course Project Presentation – Computer Networks & Security

Kashvi Gupta (2023UCP1581) & Daksh Mittal (2023UCP1592)

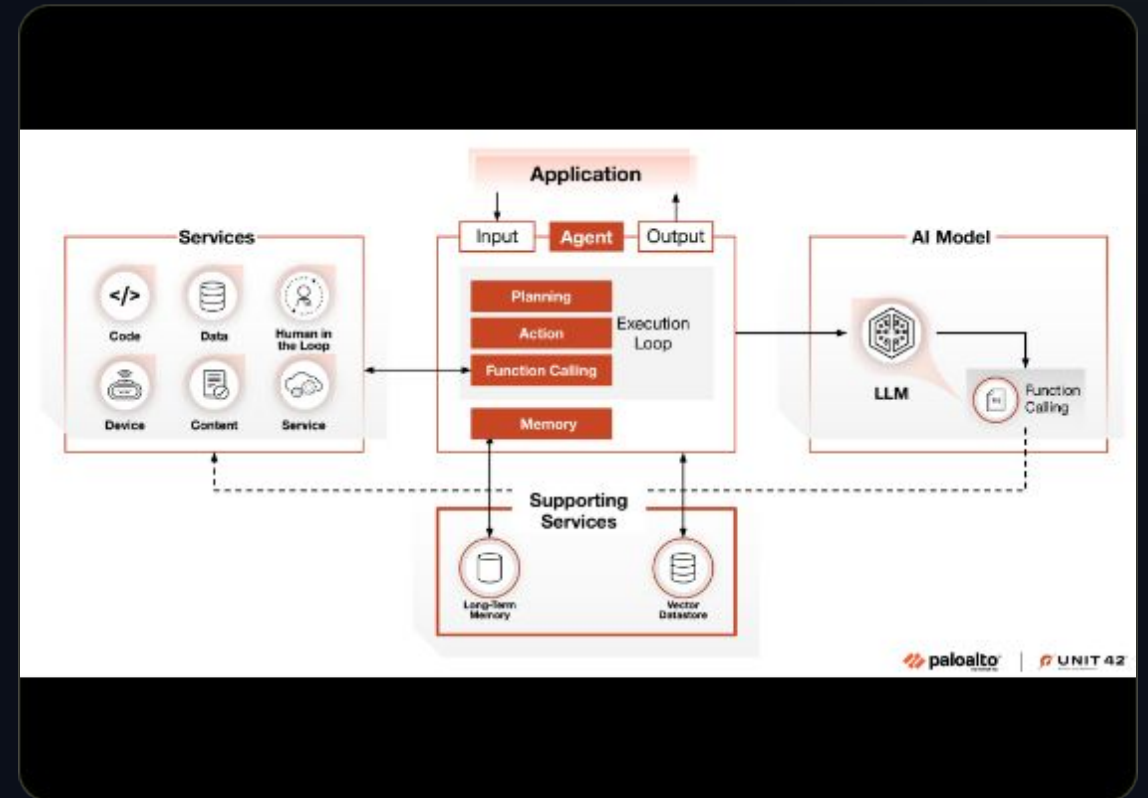
Based on Syros et al., NDSS Symposium 2026

Introduction & Motivation

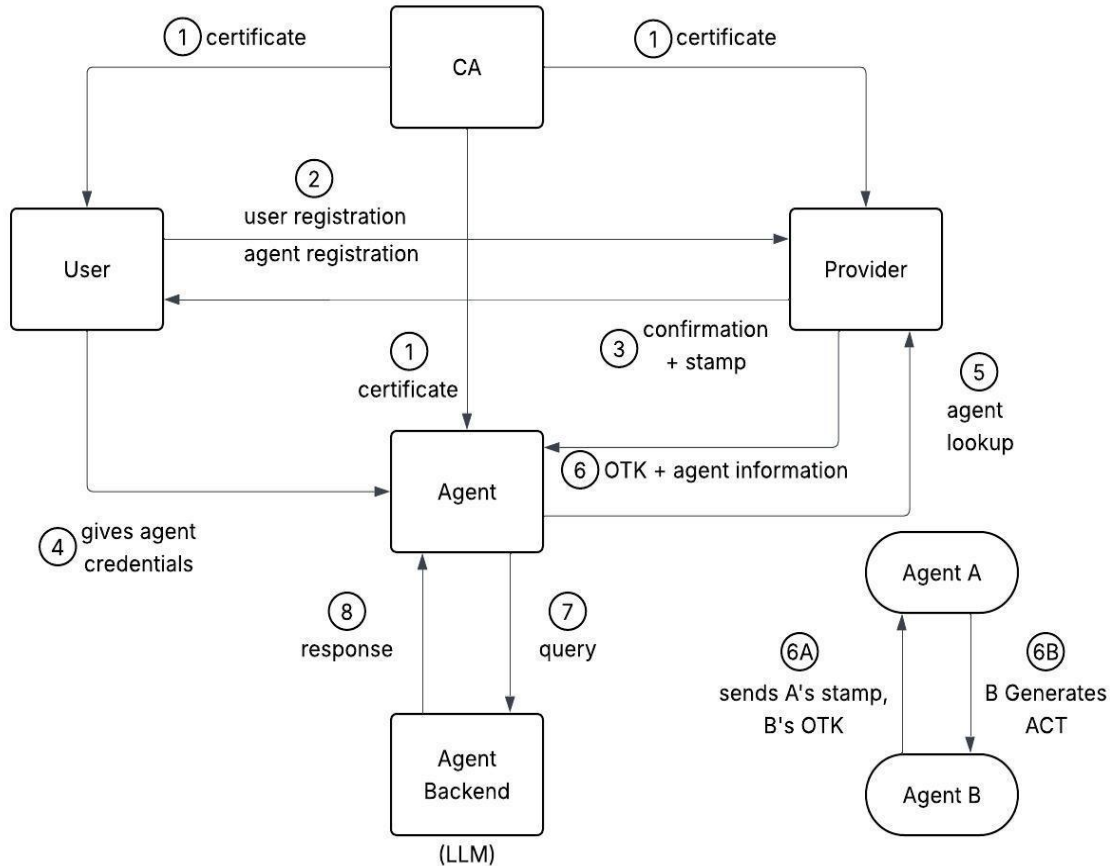
The Autonomous AI Challenge

- Multi-step LLM agents communicate autonomously across organizational boundaries.
- **Critical Security Gaps:** Lack of agent identity verification and fine-grained access policies.
- **Objective:** Secure discovery and user-controlled lifecycle management.

SAGA bridges the gap by enabling direct communication with centralized governance.



System Architecture



The Handshake Protocol

- **Centralized Provider:** Directory for agent identities and user policies.
- **Internal CA:** Signs X.509 certificates to bind endpoints to users.
- **Provider Interaction:** Initiator fetches One-Time Key (OTK) and metadata.
- **Direct mTLS:** Agents establish peer-to-peer security without a middleman.

Cryptographic Primitives



Foundations

Implemented over **Curve25519** for efficient math. Ed25519 signatures bind metadata.



Key Exchange

$$K_{\text{raw}} = \text{X25519} (sk_B , pk_{\text{OTK}})$$

Shared secret derived via **HKDF-SHA256**.



Tokens (ACT)

Access Control Tokens encrypted via **AES-GCM**. ACTs act as reusable wristbands.

Local Implementation Details

Environment

- Ubuntu 22.04 | Python 3.10
- Local MongoDB via flask_pymongo
- Qwen2.5-Coder-32B LLM Backend

0.165s

Static Protocol Overhead

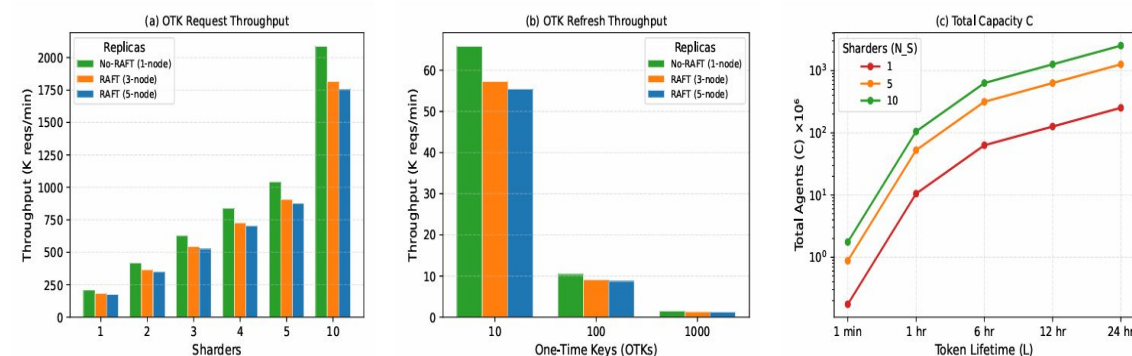
Protocol enforcement accounts for **< 0.6%** of total task execution time, proving high efficiency.

Performance & Scalability

Benchmark Summary

- **Throughput:** 208.7K requests/minute for OTK operations.
- **Linear Scaling:** Performance grows linearly with hardware nodes.
- **DB I/O Constraint:** OTK Refresh (Update) is slower than Registration (Append).

6.5.1 OTK Request and Refresh Throughput (Figure 7)



(a) OTK Request Throughput (b) OTK Refresh Throughput (c) Total System Capacity C

Figure 7: SAGA's throughput and capacity for different protocol operations. (a) OTK request throughput scales linearly with sharded nodes. (b) OTK refresh throughput decreases with key-chain length due to heavier update operations. (c) Total agent capacity $C = \mathcal{T}(N_S) \cdot L$ with 10 sharded nodes and 24-hour tokens supports over 200 M agents.

Vulnerability: DoS Exploit

OTK Exhaustion Attack

Discovered a flaw in the Provider's /access endpoint.

- Provider pops OTK **before** handshake completion.
 - Adversary loops requests to empty a victim's key pool.
 - **Impact:** Victim rendered unreachable in < 1 second.
-

Automated Mitigation

OTKRefreshAgent

A background monitoring thread built to harden agent availability.

- Polls MongoDB pool every 5 seconds.
- Authenticates via JWT and Ed25519 signatures.
- **Seamless Injection:** Replenishes keys without agent restarts.



References

- [1] G. Syros, A. Suri, J. Ginesin, C. Nita-Rotaru, and A. Oprea, "SAGA: A Security Architecture for Governing AI Agentic Systems," in Network and Distributed System Security (NDSS) Symposium, from. 2026. <https://arxiv.org/abs/2504.21034>
 - [2] Y. Shavit, S. Agarwal, M. Brundage, et al., "Practices for Governing Agentic AI Systems," Research Paper, OpenAI, 2023.
 - [3] R. Surapaneni, M. Jha, M. Vakoc, and T. Segal, "Announcing the Agent2Agent Protocol (A2A)," Google Developers Blog, April 2025.
<https://developers.googleblog.com/en/a2a-a-new-era-of-agent-interoperability/>
 - [4] A. Roucher et al., "smolagents: a smol library to build great agentic systems," <https://github.com/huggingface/smolagents>, 2025.
 - [5] B. Blanchet, B. Smyth, V. Cheval, and M. Sylvestre, "ProVerif 2.00: Automatic Cryptographic Protocol Verifier," User Manual and Tutorial, 2018.
-

THANK YOU